

for which the source code cannot be shared. It is advisable to create a guidance for developers about what to avoid coming into their code that will be shipped to the customers. It must also include services on security vulnerabilities in the components used. Many companies can't actually identify what open source is being used. Such firms need help to refer to software composition analysis tools, which can identify the licences associated with components and vulnerabilities," he says.

Balakrishna Mukundaraj, associate project manager, Bosch Global Software Technologies Pvt Ltd (BGSW), also feels it is important to develop training, policies and other processes that are necessary to achieve open source compliance across the organisation. BGSW is among the first companies to provide compliance audit services to all the different business units of Bosch worldwide. "The consultation services begin during design — companies come to us with queries about licensing at the stage of procuring components. The organisation level training is vital even for any tools that have been procured or developed in-house," he says.

"Education is the core foundation of open source compliance. An open source awareness programme for onboarding graduates will help to figure out the roadmap to be implemented within a company. At Bosch, we took this up seriously and started giving more time towards the training, which has proved very useful," he adds.

Along with training and awareness, a little knowledge about the common misnomers and challenges can help developers improve their understanding of open source compliance. The Linux Foundation offers two courses for this:

- Introduction to Open Source License Compliance Management (LFC193)
- Open Source Licensing Basics for Software Developers (LFC191)

A few myths

The software is free: The most common misunderstanding in open source is with the term 'free'. "It actually means you are free to use it and do whatever you want within your project as long as you meet the obligations of the licence," says Aykut Avci, global license compliance manager, iText Software.

As there are numerous permissive, non-permissive and copyleft licences like Apache License (permissive licence), Massachusetts Institute of Technology License (permissive licence), General Public License or GPL (non-permissive and copyleft licence), Affero GPL (non-permissive and copyleft licence) and more, it's quite difficult for a developer to know the obligations of each one of these. "The open source you use may be free, but there are different business models that can allow a certain part of it or certain functionalities to be open, and the rest is for commercial use. People frequently confuse the two. For instance, iText has a dual licence — if you use the open source copyleft licence, you will need to make the source code of your derivative work available to users, but you can purchase a commercial licence to take away the copyleft obligation," he adds.

Open source software has good quality: We expect an organisation to have a very high quality of open source. But remember, there is good and bad quality open source. The update history and commits of open source projects are a good reflection of the health of an open source component. The community is not going to check that.

Narayanam says communities do have strong pipelines and checks, but they may not work to achieve quality. Hence, always set your standards high for the open source project and the delivery project, with respect to the quality, cyber security and tooling.

Callinan says it is a myth that if it is managed commercial software, it does not have much risk. It is also a myth

that open source communities will fix everything. Some projects are managed only by one person. To check the quality of a project, look at the activity around the components, library or the package you want to bring into your software. There are tools that can reveal data about the number of commits causing a hidden risk for companies, such as the recent log4j vulnerability. "Always check how well-supported the product is," he adds.

The OpenChain Project of the Linux Foundation is a great example of how trust can be built into the complete supply chain of software.

Compliance issues are being taken care of: According to Narayanam, when developers are collaborating on an external open source project, the host may not take care of the compliance. So, how does one ensure compliance? It's best to have a common understanding of the copyright statement right from the beginning when you are contributing to or hosting a project. The advice of a legal team is mandatory.

From a quality perspective, give details on what kind of tooling you have used to ensure compliance when the code is checked. Also, place checks and balances on what level of cyber security you want to ensure.

The engineering team, developers, legal team and IP team will all need to be involved in compliance.

Licensing can be ignored: There are many different types of licences and their versions. Tools can be used to identify the components in the code, but unless you code in, they generally don't provide interpretation. As this becomes confusing, people tend to avoid using them.

"We must look at the business risk as opposed to working just with developers. Developers shouldn't have to spend time interpreting licences. Companies must put guidance in place. Also, start working with a company by attending education programmes